

AMENAZAS, VULNERABILIDADES Y RIESGOS.

Saber identificar conceptos como los de amenaza, vulnerabilidad y riesgo y cómo puede afectar un incidente a tu empresa, te permitirá saber si tu empresa está en peligro.



Vulnerabilidad y amenaza son términos que se confunden a menudo, por lo que es necesario definirlos correctamente desde el principio, al igual que ocurre con el riesgo:

Una **vulnerabilidad** (en términos de informática) es una debilidad o fallo en un sistema de información que pone en riesgo la seguridad de la información permitiendo que un atacante pueda comprometer la integridad, disponibilidad o confidencialidad de la misma. Necesitaremos por tanto encontrarlas y corregirlas lo antes posible. Estos «agujeros» pueden tener distintos orígenes, por ejemplo: fallos de diseño, errores de configuración o carencias de procedimientos.

Por otro lado, una **amenaza** es toda acción que se aprovecha de una vulnerabilidad para atacar a un sistema de información. Es decir, que podría tener un potencial efecto negativo sobre algún elemento de nuestros sistemas. Las amenazas pueden proceder de ataques (fraude, robo, virus), sucesos físicos (incendios, inundaciones) o negligencia y decisiones institucionales (mal manejo de contraseñas, no usar cifrado).

Desde el punto de vista de una organización, las amenazas pueden ser tanto internas como externas.

Por tanto, las vulnerabilidades son las condiciones y características propias de los sistemas de una organización que la hacen susceptible a las amenazas. El problema es que, en el mundo real, si existe una vulnerabilidad, siempre existirá alguien que intentará sacar provecho de su existencia.

Una vez que tenemos clara la diferencia entre amenaza y vulnerabilidad, debemos saber que el **riesgo** es la probabilidad de que se produzca un incidente de seguridad, materializándose una amenaza y causando pérdidas o daños. Se mide asumiendo que existe una cierta vulnerabilidad frente a una determinada amenaza, como puede ser un ciberdelincuente, un ataque de denegación de servicio, un virus... El riesgo depende entonces de la probabilidad de que la amenaza se materialice aprovechando una vulnerabilidad y produciendo un daño o impacto. El producto de estos factores representa el riesgo.

Asociados al riesgo, hablamos de **análisis de riesgos** cuando nos referimos al uso sistemático de la información para identificar las fuentes y calcular el riesgo, y de **gestión del riesgo**, cuando nos referimos a las actividades coordinadas para dirigir y controlar una organización con relación al riesgo.

En función de la relevancia de los riesgos podremos optar por:

- **Evitar el riesgo** eliminando su causa, por ejemplo, cuando sea viable optar por no implementar una actividad o proceso que pudiera implicar un riesgo.
- **Adoptar medidas que mitiguen el impacto o la probabilidad del riesgo** a través de la implementación y monitorización de controles.
- **Compartir o transferir el riesgo** con terceros a través de seguros, contratos etc.
- **Aceptar la existencia del riesgo** y monitorizarlo.

El tratamiento del riesgo supone unos claros beneficios para la «salud» de la ciberseguridad de nuestra empresa. De esta manera mantendremos protegida nuestra información confidencial y la de nuestros clientes frente a la mayoría de amenazas y vulnerabilidades detectadas (o no), evitando robos y fugas de información.

Algunas de las fuentes de amenazas más comunes en el ámbito de sistemas de información son:

- **Malware o código malicioso:** comentados en el apartado anterior.
- **Ingeniería social:** Utilizan técnicas de persuasión que aprovechan la buena voluntad y falta de precaución de la víctima para obtener información sensible o confidencial. Los datos así obtenidos son utilizados posteriormente para realizar otro tipo de ataques, o para su venta.
- **APT o Amenazas Persistentes Avanzadas** (Advanced Persistent Threats): son ataques coordinados dirigidos contra una empresa u organización, que tratan de robar o filtrar información sin ser identificados. Se suelen ayudar de técnicas de ingeniería social y son difíciles de detectar.
- **Botnets:** conjunto de equipos infectados que ejecutan programas de manera automática y autónoma, que permite al creador del botnet controlar los equipos infectados y utilizarlos para ataques más sofisticados como ataques DDoS.
- **Redes sociales:** el uso no controlado de este tipo de redes puede poner en riesgo la reputación de la empresa.
- **Servicios en la nube:** una empresa que contrate este tipo de servicios tiene que tener en cuenta que ha de exigir los mismos criterios de seguridad que tiene en sus sistemas a su proveedor de servicios. Se ha de asegurar de contratarlos con empresas cuya seguridad este demostrada, y firmar SLA o ANS (Acuerdos de Nivel de Servicio) en los que quede definida la seguridad que necesita la empresa.
- Algunos incidentes pueden implicar **problemas legales** que pueden suponer sanciones económicas y daños a la reputación e imagen de la empresa. Por eso, es importante conocer los riesgos, medirlos y evaluarlos para evitar en la medida de lo posible los incidentes, implantando las medidas de seguridad adecuadas.

4. BUENAS PRÁCTICAS.

4.1. SEGURIDAD FÍSICA.

La seguridad física de los sistemas informáticos consiste en la aplicación de barreras físicas y procedimientos de control como medidas de prevención y detección, destinados a proteger físicamente cualquier recurso del sistema.

Este hecho cobra vital importancia en aquellos equipos (portátiles, tablets o smartphones) que salen de la empresa para desarrollar su trabajo.

Dependiendo del entorno y los sistemas a proteger esta seguridad será más o menos importante y restrictiva, aunque es preferible pecar de exceso de celo: mínima exposición/mínimo privilegio.

Por otro lado, tenemos que interiorizar el concepto de **resiliencia**, que hace referencia a la capacidad de una empresa de adaptarse y continuar con sus funciones y su trabajo en situaciones de riesgo. Cómo actuar y cómo **gestionar la situación de forma eficiente** afectando el mínimo posible al desempeño general de la empresa. O, en otras palabras, una empresa es resiliente si tiene implementadas las medidas correctas para reestablecer cualquier servicio en el menor tiempo posible cuando se ha producido un incidente de seguridad/ciberseguridad.

A continuación, destacaremos algunos de los problemas de seguridad física con los que nos podemos enfrentar y las medidas que podemos tomar para minimizar su impacto.

Debemos realizar una monitorización continua de nuestra infraestructura para conocer, en tiempo real, la situación de riesgo en la que nos encontramos y, además, debemos fomentar una cultura de la seguridad empresarial educando a todos los miembros de la empresa en buenas prácticas para evitar riesgos y saber cómo actuar en caso de incidente.

PROTECCIÓN DEL HARDWARE

Problemas a los que nos enfrentamos:

- Acceso físico.
- Desastres naturales.
- Alteraciones del entorno.
- Acceso al propio dispositivo informático.

ACCESO FÍSICO

Si alguien que desee atacar un sistema tiene acceso físico al mismo todo el resto de medidas de seguridad implantadas se convierten en inútiles. Esto no sería un gran problema si protegiésemos lo que habitualmente no protegemos correctamente: ni los espacios en los que ubicamos nuestros equipos informáticos, ni el acceso a los mismos.

En cuanto a proteger el espacio en el que tenemos nuestros equipos informáticos, deberemos implantar mecanismos de **prevención** (control de acceso a los recursos) y de

detección (si un mecanismo de prevención falla o no existe debemos al menos detectar los accesos no autorizados cuanto antes).

Para la **prevención** hay muchas posibilidades que permiten registrar quien accede a qué recursos y en qué momento:

- Sistemas Biométricos: analizadores de retina, lectores de huellas digitales, ...
- Tarjetas inteligentes.
- CCTVs.
- ...

En muchos casos es suficiente con controlar el acceso a las salas y cerrar siempre con llave los despachos o salas donde hay equipos informáticos y no tener cableadas las tomas de red que estén accesibles.

DESASTRES NATURALES

Además de los posibles problemas causados por ataques realizados por personas, es importante tener en cuenta que también los *desastres naturales* pueden tener muy graves consecuencias, sobre todo si no los contemplamos en nuestra política de seguridad y su implantación.

Algunos desastres naturales a tener en cuenta:

- Terremotos y vibraciones.
- Tormentas eléctricas.
- Inundaciones y humedad.
- Incendios y humos.

Los terremotos son el desastre natural menos probable en un país como España, por lo que no se harán grandes inversiones en prevenirlos, sin embargo, si fuéramos a abrir una delegación en Japón, la situación cambiaría drásticamente. Además, hay varias cosas que se pueden hacer sin un desembolso elevado y que son útiles para prevenir problemas causados por pequeñas vibraciones:

- No situar equipos en sitios altos para evitar caídas.
- No colocar elementos móviles sobre los equipos para evitar que caigan sobre ellos.
- Separar los equipos de las ventanas para evitar que caigan por ellas o qué objetos lanzados desde el exterior los dañen.
- Utilizar fijaciones para elementos críticos.
- Colocar los equipos sobre plataformas de goma para que esta absorba las vibraciones.

Otro desastre natural importante son las tormentas con aparato eléctrico, especialmente frecuentes en verano, que generan subidas súbitas de tensión muy superiores a las que pueda generar un problema en la red eléctrica. A parte de la protección mediante el uso de

bases de enchufe con toma de tierra, podemos usar SAIs que mantengan encendidos los equipos críticos en caso de pérdida de corriente. En estos casos es recomendable desconectar los equipos cuando haya tormenta.

En entornos normales es recomendable que haya un cierto grado de humedad, ya que en si el ambiente es extremadamente seco hay mucha electricidad estática. No obstante, tampoco interesa tener un nivel de humedad demasiado elevado, ya que puede producirse condensación en los circuitos integrados que den origen a un cortocircuito. En general no es necesario emplear ningún tipo de aparato para controlar la humedad, pero no está de más disponer de alarmas que nos avisen cuando haya niveles anómalos.

Otro tema distinto son las inundaciones, ya que casi cualquier medio (servidores, routers o switches, sistemas de almacenamiento y backup de datos, ...) que entre en contacto con el agua queda automáticamente inutilizado, bien por el propio líquido o bien por los cortocircuitos que genera en los sistemas electrónicos. Contra ellas podemos instalar sistemas de detección que apaguen los sistemas si se detecta agua y corten la corriente en cuanto estén apagados. Hay que indicar que los equipos deben estar por encima del sistema de detección de agua, sino cuando se intente parar ya estará mojado.

Por último, mencionaremos el fuego y los humos, que en general provendrán del incendio de equipos por sobrecarga eléctrica. Contra ellos emplearemos sistemas de extinción, actualmente son más o menos inocuos y nos evitarán males mayores. Además del fuego, también el humo es perjudicial para los equipos (incluso el del tabaco), al ser un abrasivo que ataca a todos los componentes, por lo que es recomendable mantenerlo lo más alejado posible de los equipos.

ALTERACIONES DEL ENTORNO

En nuestro entorno de trabajo hay factores que pueden sufrir variaciones que afecten a nuestros sistemas que tendremos que conocer e intentar controlar.

Deberemos contemplar problemas que pueden afectar el régimen de funcionamiento habitual de las máquinas como la alimentación eléctrica, el ruido eléctrico producido por los equipos o los cambios bruscos de temperatura.

Electricidad

Quizás los problemas derivados del entorno de trabajo más frecuentes son los relacionados con el sistema eléctrico que alimenta nuestros equipos; cortocircuitos, picos de tensión, cortes de flujo ...

Como hemos indicado anteriormente, para corregir los problemas con las subidas de tensión podremos instalar tomas de tierra o filtros reguladores de tensión y SAIs (Sistemas de Alimentación Ininterrumpida).

Por último, indicar que además de los problemas del sistema eléctrico también debemos preocuparnos de la corriente estática, que puede dañar los equipos. Para evitar problemas se pueden emplear espráis antiestáticos o ionizadores y tener cuidado de no tocar componentes metálicos, evitar que el ambiente esté excesivamente seco, etc.

Ruido eléctrico

El ruido eléctrico suele ser generado por motores o por maquinaria pesada, pero también puede serlo por otros ordenadores o por multitud de aparatos, y se transmite a través del espacio o de líneas eléctricas cercanas a nuestra instalación.

Para prevenir los problemas que puede causar el ruido eléctrico debemos no situar el *hardware* cerca de los elementos que pueden causar el ruido. En caso de que fuese necesario hacerlo siempre podemos instalar filtros o apantallar las cajas de los equipos.

Temperaturas extremas

No hace falta ser un genio para comprender que las temperaturas extremas, ya sea un calor excesivo o un frío intenso, perjudican gravemente a todos los equipos. En general es recomendable que los equipos operen entre 10 y 32 grados Celsius. Para controlar la temperatura emplearemos aparatos de aire acondicionado.

Protección de los datos

Además de proteger el hardware, nuestra política de seguridad debe incluir medidas de protección de los datos, ya que en realidad la mayoría de ataques tienen como objetivo la obtención de información, no la destrucción del medio físico que la contiene.

Soportes no electrónicos

Otro elemento importante en la protección de la información son los elementos no electrónicos que se emplean para transmitirla, fundamentalmente el papel. Es importante que en las organizaciones que se maneje información confidencial se controlen los sistemas que permiten exportarla tanto en formato electrónico como en no electrónico (impresoras, plotters, faxes, ...).

Cualquier dispositivo por el que pueda salir información de nuestro sistema ha de estar situado en un lugar de acceso restringido; también es conveniente que sea de acceso restringido el lugar donde los usuarios recogen los documentos que lanzan a estos dispositivos.

Además de esto es recomendable disponer de trituradoras de papel para destruir todos los papeles o documentos que se quieran destruir, ya que evitaremos que un posible atacante pueda obtener información rebuscando en nuestra basura.

ACCESO AL PROPIO DISPOSITIVO INFORMÁTICO

Debemos acostumbrarnos a utilizar contraseña de BIOS en todos los equipos y dispositivos informáticos, más aún en aquellos que sacamos de la empresa.

Además, usaremos contraseñas seguras de acceso al sistema operativo, que obligaremos a cambiar con la periodicidad que establezcamos.

Por último, debemos cifrar los discos duros de los dispositivos, para que la información sea ilegible en caso de caer en manos de quien no debiera. En tablets y smartphones, podemos configurar el borrado remoto del dispositivo en el caso de que nos le hayan sustraído o le hayamos perdido.

4.2. COPIAS DE SEGURIDAD.

Ya hemos comentado que lo que realmente tiene valor en la empresa es la información y necesitamos disponer de un procedimiento de copia de seguridad y otro, paralelo, de restauración de la copia.

El sistema de copia de seguridad que implementaremos dependerá de la información que debamos proteger y dónde esté almacenada. No utilizarán los mismos procedimientos las empresas si virtualizan sus sistemas o si no lo hacen, o si disponen, o no, de sistemas gestores de bases de datos, o si utilizan sistemas operativos Windows o los usan Linux, ...

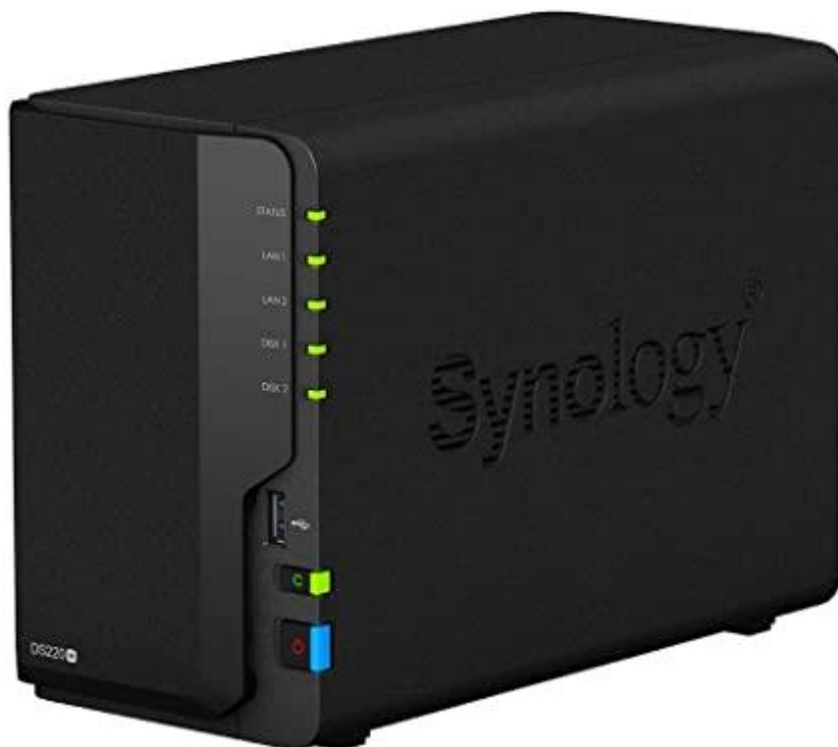
Por eso, antes de nada, hay que hacer una auditoría que nos permita elegir la solución que mejor se adapte a nuestras necesidades.

Por otro lado, debemos combinar las copias de seguridad que almacenamos “en local”, en nuestras oficinas, con copias de seguridad en la nube. Actualmente los costes de estos servicios son asumibles y permiten tener, fuera de la empresa, una copia de seguridad que nos permita continuar con nuestra actividad en caso de una catástrofe.

Aunque sean situaciones extremas, recuerda lo ocurrido en los atentados del 11 de septiembre en Estados Unidos, o el incendio del edificio Windsor en Madrid. Las empresas que tenían oficinas en esos edificios, y no tenían copias de seguridad online, no pudieron continuar con su actividad al no poder recuperar la información, aunque tenían copias de seguridad en sus oficinas.

Para entornos con servidores Windows Server, podemos utilizar la herramienta de copia de seguridad que viene integrada en el propio sistema.

Una opción muy interesante es la utilización de discos duros/servidores tipo Synology NAS



El **NAS** (Network Attached Storage) es un dispositivo de almacenamiento inteligente conectado a su red doméstica o de oficina. ... Mediante un explorador web o aplicaciones móviles, puede acceder a los archivos y utilizar diversos servicios proporcionados por el **NAS** a través de Internet.

Los NAS Synology se utilizan sobre todo para...

- **centralizar y almacenar datos.**
- **hacer copias de seguridad de datos.**
- **hacer copias de seguridad de puestos de trabajo.**
- **compartir archivos.**
- **trabajar en colaboración en un documento.**
- **sincronizar archivos entre dispositivos.**
- **realizar videovigilancia.**
- **crear un media center.**

Os dejo una guía completa paso a paso de como utilizar un Synology.

Los precios de este disco duro/servidor están entre los 180 y los 800 euros, dependiendo de la capacidad que se desee tener.

4.3. CONTRASEÑAS SEGURAS.

Las contraseñas son el sistema más utilizado para autenticarnos cuando necesitamos acceder a algún tipo de servicio. Sin embargo, son uno de los principales dolores de cabeza de los profesionales que se encargan de la seguridad de las organizaciones.

¿Por qué? Sobre todo, por la incapacidad que tenemos de recordar más de tres o cuatro contraseñas complejas. Habitualmente, todos utilizamos esas tres o cuatro contraseñas para acceder a todo: desde redes sociales a servicios bancarios, pasando por los inicios de sesión de nuestros ordenadores.

El problema es que cuando una de nuestras contraseñas ha sido comprometida se ven comprometidos todos los servicios en los que usamos esa contraseña.

Siguiendo unas sencillas pautas, minimizamos enormemente el problema, sin embargo, muy pocas personas las aplican:

- Utilizar una contraseña para cada servicio.
- Utilizar contraseñas complejas, que combinen números, letras (mayúsculas y minúsculas) y caracteres especiales.
- Utilizar contraseñas que no estén vinculadas con datos personales: fechas de nacimiento, nombres de familiares o mascotas, ...
- Cambiar con cierta periodicidad esas contraseñas.
- Utilizar dobles factores de autenticación: pines enviados al móvil, tarjetas de coordenadas, ... Estos sistemas si solemos usarlos en nuestros accesos a banca online, pero no extendemos su uso a otros servicios.
- Utilizar algún servicio de gestión de contraseñas centralizado.

Por otro lado, el problema de las contraseñas aumenta en el espacio de trabajo. O directamente no las usamos, o todos los compañeros conocen las contraseñas de todos, o las tenemos apuntadas en póst-it pegadas en los monitores, ...

Si tenemos en cuenta que lo único que necesita un ciberdelincuente para acceder a nuestros sistemas son un nombre de usuario y una contraseña, debemos entender el problema que surge si no gestionamos correctamente las contraseñas en nuestra empresa.

Es más que evidente que el uso de contraseñas no es, ni de lejos, el mejor sistema para asegurar el acceso a los servicios que necesitamos utilizar (más por nuestra culpa que porque el sistema no sea robusto si se usa como se debe) y se está trabajando en encontrar sistemas que sustituyan la necesidad de utilizarlas, como por ejemplo sistemas biométricos, el uso del smatphone, ...

Algunos de estos sistemas, ya disponibles, llaman la atención por su originalidad:

- **El uso de nuestro corazón para identificarnos:**

El sistema utiliza un **Radar Doppler** de baja intensidad para medir los latidos de corazón de una persona y luego lo monitorea continuamente para otorgarle acceso a su computadora o a un área restringida.

Podéis ampliar la información desde este enlace: <https://goo.gl/m9ZM1L>

- **PalmSecure ID Login de Fujitsu:**

La nueva solución de Fujitsu **que lee las venas de la palma de la mano y su oxígeno**, es una nueva solución de autenticación biométrica, que ayuda a las organizaciones a proteger sus redes contra el acceso no autorizado, al mismo tiempo que reduce el riesgo de ataques de ciberdelinquentes y suplantadores de identidad.

Podéis ampliar la información desde este enlace: <https://goo.gl/WysgTp>

En definitiva, debemos tener presente que una buena gestión de las contraseñas reduce la posibilidad de padecer un incidente de seguridad, explicando a los trabajadores la importancia de usar contraseñas seguras y los riesgos que estamos asumiendo al utilizar las contraseñas como lo está haciendo la mayoría hasta la fecha.

4.4. DISPOSITIVOS MÓVILES.

Los dispositivos móviles, portátiles que usamos desde hace años, y tablets y smartphones, que usamos desde hace poco para facilitarnos el trabajo en movilidad, son otra de las fuentes de problemas ya que habitualmente no les integramos en nuestras políticas de seguridad.

Gracias a ellos se ha roto el perímetro, que dicen los especialistas en seguridad. Esto hace referencia a que hace unos años con proteger el perímetro de nuestra infraestructura era suficiente. Este perímetro venía definido por nuestros routers por los que nuestros equipos salen hacia el exterior. Sin embargo, hoy día casi hay más dispositivos fuera de la empresa accediendo a recursos internos que equipos informáticos dentro. Y esto plantea un problema porque debemos proteger todos esos dispositivos y las comunicaciones necesarias para que desarrollen su actividad.

¿POR QUÉ DEBEMOS PROTEGER ESTOS DISPOSITIVOS?

Fundamentalmente porque con ellos accedemos a recursos internos y en ellos almacenamos información confidencial, como por ejemplo correos electrónicos, datos de contacto de mis clientes y proveedores, documentos como presupuestos, proyectos y fotografías, credenciales de acceso (usuario|contraseña), ...

Además, en muchas ocasiones, para acceder a estos servicios nos conectamos a redes inseguras, tanto en nuestros domicilios, como en hoteles, restaurantes, aeropuertos, ..., sin implementar ningún sistema de acceso seguro que garantice una comunicación protegida de extremo a extremo y en la que la información se envíe cifrada.

Recuerda que, digan lo que digan los fabricantes (todo es publicidad), tan inseguros son los dispositivos basados en Android, como los que se basan en IOS de Apple o los de Microsoft, estos últimos en un porcentaje muy reducido en comparación con los otros dos.

¿CÓMO PODEMOS PROTEGER NUESTROS DISPOSITIVOS?

- Usando contraseña o patrón.
- Teniendo anotado el IMEI para anular el dispositivo en caso de robo o pérdida. Hoy día esta información suele estar disponible desde la web del proveedor de comunicaciones, cuando accedemos a nuestro espacio personal. Si no la localizamos debemos ponernos en contacto telefónicamente con la operadora.
- Utilizar dos dispositivos distintos, uno en el ámbito personal y otro en el ámbito profesional
- Cifrar el dispositivo. Esta es una opción de seguridad que permiten todos los dispositivos hoy día pero que casi nadie usa.
- Teniendo instaladas aplicaciones de control remoto del dispositivo que nos permitan:
 - Saber dónde está por geolocalización.
 - Eliminar la información.
- Realizando copias de seguridad de la información del dispositivo en la nube o en equipos internos de la empresa.
- Instalando software antivirus.
- Evitando hacer rooting o jailbreaking de los dispositivos. Estos son procedimientos que permiten desbloquear los dispositivos para poder instalar aplicaciones no oficiales o instalar apps oficiales sin pagarlas.
- Asegurándonos de que las apps que nos descargamos son legítimas, aunque las descarguemos de las stores oficiales de Google, Apple o Microsoft.
- No utilizando apps gratuitas. Cuando algo es gratis el precio somos nosotros mismos (nuestra información).
- Actualizar los sistemas operativos de los dispositivos cuando los fabricantes ofrecen actualizaciones que, aparte de ofrecernos nuevas funcionalidades, corrigen vulnerabilidades detectadas.

¿CÓMO PODEMOS PROTEGER NUESTRAS COMUNICACIONES?

- Intentando evitar redes públicas.
- Usando herramientas VPNs, Redes Privadas Virtuales, que autentican la conexión desde el exterior (usuario|contraseña) y cifran la información que se transmite).
- Usando sistemas de escritorio remoto como Citrix, Parallels, VmWare u otros, que permiten acceder a la información y recursos de la organización, desde el exterior, evitando la necesidad de tener almacenada esa información en el dispositivo.
- Incorporar a los dispositivos móviles en las políticas de seguridad de los sistemas de servidores y gestionarlos igual que gestionamos los equipos internos, con Políticas de Grupos en Windows Server (GPOs), por ejemplo.

CONCLUSIONES

Tenemos un arma muy poderosa en nuestras manos, que nos permite ser mucho más productivos si lo usamos como debemos, pero desde el que podemos causar graves perjuicios a la empresa si lo utilizamos de una forma indebida o si lo perdemos, nos lo roban o nos lo infectan con un malware que permita monitorizar nuestras comunicaciones o que acceda al interior de nuestros sistemas cuando conectemos nuestro dispositivo a nuestros equipos informáticos para cargarlos, por ejemplo.

Entiende que estos dispositivos son como cualquier otro equipo de tu organización que debes proteger e integrar en tus políticas de seguridad. Hay que tenerlos mucho más vigilados porque, a diferencia de los otros, estos salen de tu empresa llevando información confidencial que no debe caer en manos de terceros.

Usa tus dispositivos con sentido común. En la mayoría de las ocasiones esto ya minimiza el riesgo de que nuestro dispositivo móvil origine un incidente de seguridad en nuestra empresa.

Para finalizar, debemos desarrollar periódicamente formaciones/concienciaciones entre nuestros trabajadores para que entiendan el riesgo que asumen al utilizar estos dispositivos y cómo se pueden evitar riesgos originados por un uso inadecuado.

Si vamos a permitir que nuestros trabajadores usen sus dispositivos personales (portátiles, tablets, smartphones o pinchos/discos usb), lo que hoy día se denomina BYOD (Bring Your Own Device) implementa las medidas de seguridad oportunas.

Ten en cuenta que cuando intenten atacar a tu empresa, siempre intentarán hacerlo a través del eslabón más débil y este siempre es el trabajador. Comprometeremos al trabajador, infectaremos sus dispositivos y accederemos a los sistemas internos de la empresa a través de ellos.

4.5. PROBLEMAS DE SEGURIDAD EN NUESTRAS REDES. REDES WIFI.

En este punto vamos a hacer referencia a la seguridad de las redes wifi que nosotros gestionamos. Las consideraciones sobre cómo utilizar nuestros dispositivos móviles de forma segura en redes wifi públicas, que nosotros no controlamos ni gestionamos, ya se han indicado anteriormente.

En nuestras empresas podemos se puede dar una de las siguientes situaciones:

1. El router de acceso a Internet es, simultáneamente, nuestro punto de acceso Wifi.
2. Utilizamos un router para acceder a Internet y disponemos de APs (puntos de acceso) Wifi a los que nos conectamos con nuestros dispositivos móviles.

En el primer caso debemos tener especial cuidado ya que comprometer el router puede provocar muchos más problemas de seguridad que si los comprometidos son sólo los APs Wifi.

Sin embargo, en la mayoría de los casos, comprometer el router es muy sencillo ya que prácticamente nadie cambia las credenciales de acceso al dispositivo.

Cuando contratamos el servicio de telefonía e internet con una operadora de comunicaciones, viene un operario de la misma para hacer la instalación del router que nos da el servicio.

Este comprueba que el servicio está operativo, nos facilita la clave de acceso a la Wifi, y se marcha. Lo que no se molesta en decirnos es que todos los routers tienen un usuario administrativo con una clave de acceso por defecto que usaremos cuando queramos acceder al dispositivo para configurarlo: servicio DHCP, DNS, Firewall, o cambiar el SSID y la clave por defecto de la Wifi, entre otros aspectos.

Sabiendo cual es la marca y modelo del router y realizando una búsqueda en Google, tardamos 30 segundos en conocer cual es el nombre del usuario administrador y su clave de acceso al dispositivo.

Lo mejor de todo es que no necesitamos estar cerca. Podemos acceder a los dispositivos en remoto, a través de la dirección ip pública del router y esta podemos obtenerla utilizando buscadores como Shodan y otros.

Una vez conocemos la ip pública y el usuario y contraseña de la cuenta del administrador, podemos acceder al dispositivo y cambiar la configuración para:

- Modificar las direcciones IP de los servidores DNS para que todas las consultas de resolución de nombres pasen por nuestros DNS. Esto nos va a permitir saber a qué servicios se conectan los trabajadores.
- Esnifar (capturar) el tráfico saliente para intentar sacar usuarios y contraseñas de servicios internos.
- Modificar las tablas ARP del router. Este es un procedimiento por el que se vinculan las direcciones IP con las direcciones MAC de mis dispositivos. De esta forma conseguimos que sólo nuestros dispositivos accedan a nuestra red y, por consiguiente, a nuestros servicios.

- Cambiar los SSID de nuestras redes Wifi o cambiar las claves de acceso a las mismas provocando un ataque de denegación de servicio al impedir que los usuarios puedan acceder a la red Wifi.

SEGURIDAD EN NUESTRAS REDES WIFI

Este sistema sencillo de instalar, configurar y gestionar nos supone un ahorro de costes importante, al evitar que tengamos que instalar cableado estructurado para que nuestros usuarios se conecten a los servicios y recursos necesarios para desarrollar su actividad, ya que accedemos a ellos de forma inalámbrica.

El problema radica en que no podemos limitar la señal wifi impidiendo que alguien desde fuera de nuestra empresa se pueda conectar.

Por este motivo debemos:

- Cambiar de forma periódica la contraseña de acceso a la Wifi y asegurarnos de que la contraseña es lo suficientemente robusta como para resistir un ataque por fuerza bruta.
- No compartir la clave de la Wifi con nadie.
- Si necesitamos permitir que personas externas a la empresa accedan a nuestra wifi, configura un SSID específico para ello. Desde este:
 - Limitaremos el ancho de banda que permitimos usar. ○ No se podrá acceder a los recursos y servicios internos.
 - Filtraremos el tipo de páginas que se visitan desde ella, evitando el acceso a páginas con contenidos inapropiados, desde los que se descargan contenidos protegidos por propiedad intelectual, ...

Debes tener en cuenta que nos tocará dar explicaciones si un usuario realiza algún acto delictivo utilizando nuestra infraestructura informática. Como veremos a continuación, con el nuevo Reglamento General de Protección de Datos, que viene a sustituir a la antigua Ley Orgánica de Protección de Datos, la seguridad debe ser proactiva y ya no va a servir el “no lo sabía”.